



UNIVERSIDAD TECNOLÓGICA DE LA ZONA
METROPOLITANA DE GUADALAJARA.



DATOS DEL ESTUDIANTE	
Nombre:	Alejandro Mixteco Tlecuile José Daniel Vázquez Barragán Carlos Ivan Machuca Ochoa
Matrícula:	5124280002 5124280012 5124280009
Fecha de elaboración:	04/03/2026
Nombre de la materia:	Arquitectura de software
Nombre de la actividad:	Proyecto integrador
Nombre del profesor:	Ricardo Ortiz Ponce
Programa educativo:	IDGS

Descripción del proyecto

En la actualidad, el envejecimiento de la población representa uno de los principales retos sociales y de salud. Muchas personas adultas mayores viven solas o pasan gran parte del día sin supervisión constante, lo que aumenta el riesgo ante situaciones como caídas, descompensaciones cardíacas, olvidos en la toma de medicamentos o emergencias médicas. A esto se suma que, en muchos casos, los familiares no pueden brindar atención permanente debido a sus actividades laborales, y no todas las familias cuentan con los recursos para contratar personal especializado.

Esta situación genera preocupación, falta de monitoreo continuo y, en algunos casos, atención tardía ante incidentes que podrían evitarse o atenderse con mayor rapidez si existiera un sistema de vigilancia preventiva y accesible.

Ante esta problemática surge Pulso, un sistema integral enfocado en el cuidado y monitoreo de adultos mayores mediante el uso de tecnologías modernas que mejoran su bienestar y seguridad. El sistema está compuesto por un reloj inteligente, una bocina inteligente y una aplicación móvil, todos integrados para ofrecer supervisión constante y atención oportuna.

El reloj inteligente permite el monitoreo continuo de signos vitales, como el ritmo cardíaco, y cuenta con detección automática de caídas. En caso de emergencia, el dispositivo envía alertas inmediatas a los contactos previamente registrados, facilitando una respuesta rápida y efectiva.

La bocina inteligente, a través del asistente de voz Alexa, funciona como un medio de comunicación sencillo y accesible. Mediante comandos de voz, el adulto mayor puede solicitar ayuda o recibir recordatorios para la toma de medicamentos, promoviendo mayor autonomía sin complicaciones tecnológicas.

Por su parte, la aplicación ofrece un panel de control centralizado donde familiares, cuidadores o personal médico pueden visualizar en tiempo real los datos de salud del usuario. Esto permite un seguimiento remoto eficiente y una toma de decisiones más ágil ante cualquier anomalía.

En conjunto, Pulso se posiciona como una solución tecnológica integral que responde a una necesidad real: brindar seguridad, monitoreo y tranquilidad tanto a los adultos mayores como a sus familias, especialmente en contextos donde no es posible contar con supervisión física permanente.

Frameworks y Tecnologías Utilizadas

1. Aplicación Web

Vue.js 3 + Node.js + Express.js + MongoDB

El sistema Pulso está construido sobre una arquitectura moderna basada en tecnologías web que permiten procesamiento en tiempo real, alta escalabilidad y manejo eficiente de datos de salud.

A) Vue.js 3 – Desarrollo del Dashboard Web

Función en el proyecto:

Vue.js 3 se utiliza para desarrollar el dashboard web donde cuidadores, familiares o personal médico monitorean en tiempo real el estado del adulto mayor.

Justificación:

Esta tecnología es ideal porque permite actualizar información dinámicamente sin necesidad de recargar la página, algo fundamental cuando se trabaja con datos de salud que cambian constantemente.

Aplicaciones dentro del proyecto:

- Actualización automática de datos cada 5 segundos sin afectar el rendimiento de la interfaz.
- Visualización de gráficos en tiempo real de frecuencia cardíaca.
- Notificaciones y alertas instantáneas ante emergencias (caídas o botón SOS).
- Gestión visual de medicamentos mediante calendario interactivo.
- Historial médico navegable con generación y exportación de reportes en PDF.

Gracias a su sistema reactivo, Vue.js garantiza una experiencia fluida y clara para el usuario.



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

B) Node.js + Express.js – Backend del Sistema

Función en el proyecto:

Node.js junto con Express.js conforman el backend del sistema, encargado de recibir, procesar y distribuir toda la información generada por los dispositivos.

Justificación:

Node.js permite manejar múltiples conexiones simultáneamente en tiempo real, lo que lo hace ideal para un sistema donde varios smartwatches pueden estar enviando datos de manera constante.

Aplicaciones dentro del proyecto:

- Procesamiento simultáneo de datos provenientes de múltiples dispositivos (envíos cada 5–30 segundos).
- Ejecución precisa de recordatorios de medicamentos en los horarios programados.
- Respuesta a emergencias en menos de 3 segundos (detección de caída → envío de alerta → activación de asistente de voz).
- Coordinación de llamadas de emergencia cuando se activa el botón SOS.
- Integración con servicios externos como plataformas de salud y notificaciones push.

Esta arquitectura permite que el sistema funcione de manera rápida, estable y escalable.

C) MongoDB – Base de Datos

Función en el proyecto:

MongoDB se utiliza como sistema de almacenamiento de datos.

Justificación:

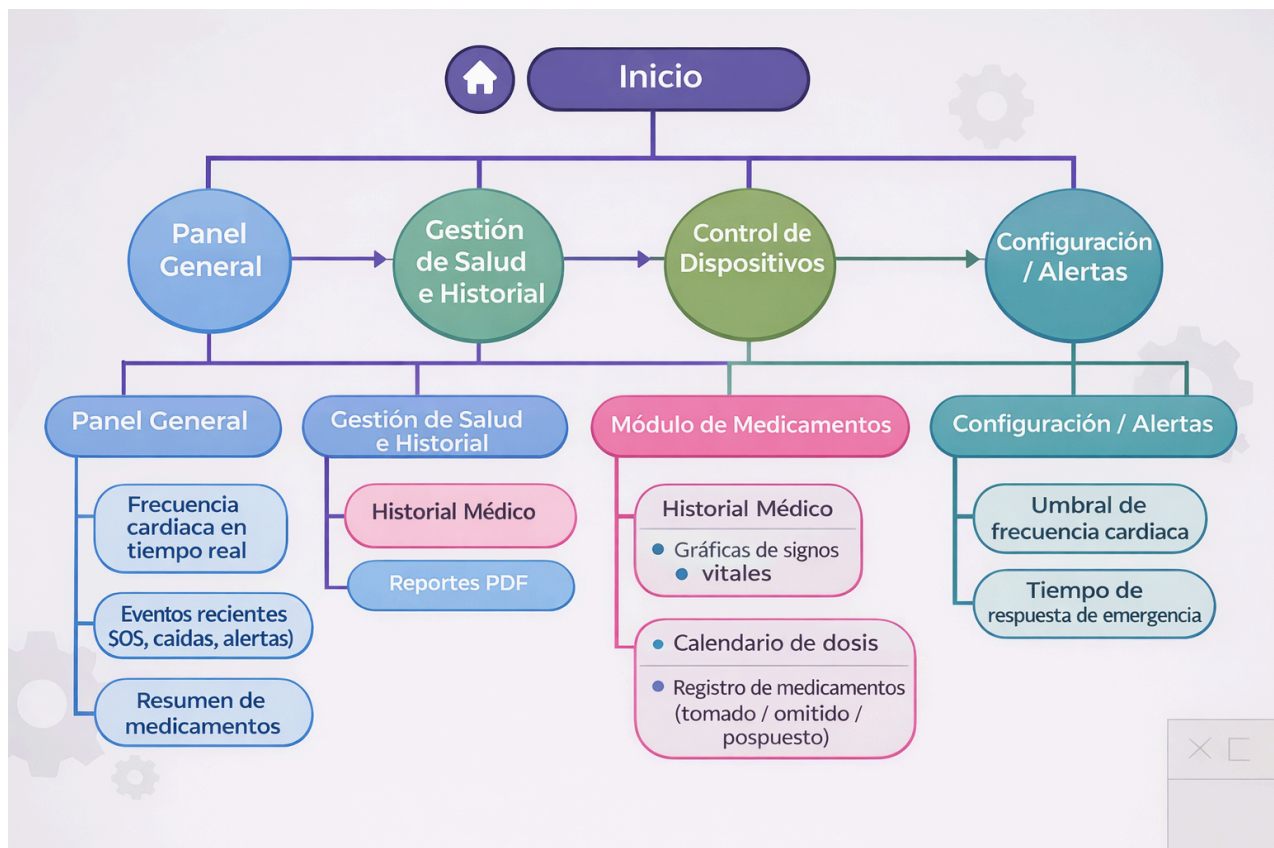
Los datos médicos son variables y personalizados. Cada adulto mayor puede tener distintos sensores, medicamentos o condiciones médicas. MongoDB, al ser una base de datos NoSQL orientada a documentos, permite manejar esta flexibilidad sin necesidad de modificar estructuras rígidas.

Aplicaciones dentro del proyecto:

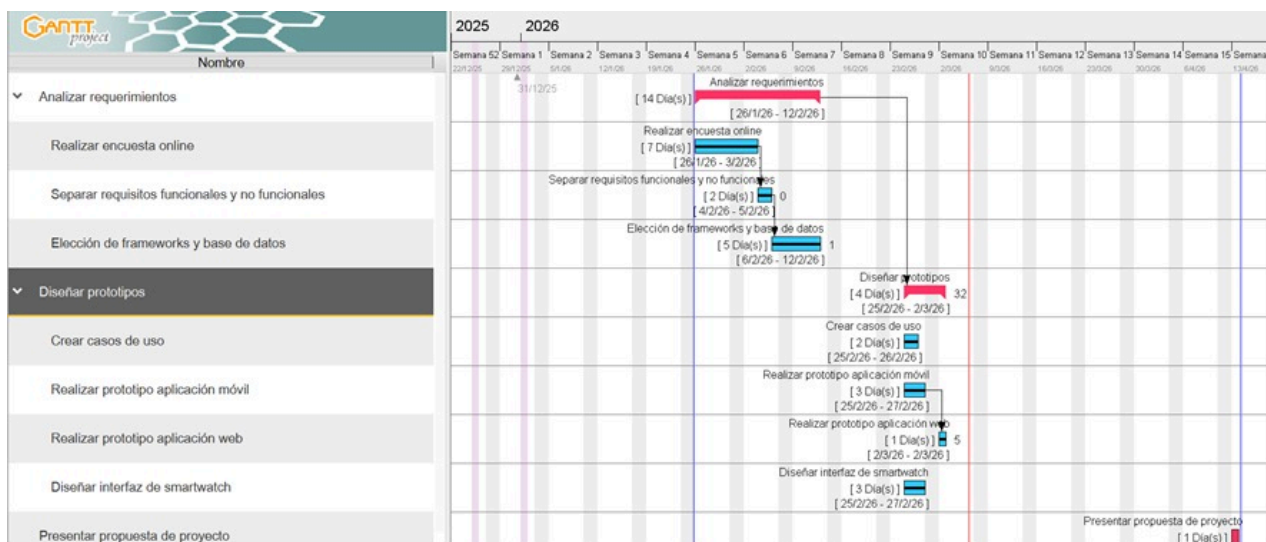
- Almacenamiento eficiente de miles de registros diarios de frecuencia cardíaca.
- Registro detallado de eventos de emergencia (caídas con intensidad, ubicación y tiempo de respuesta).
- Historial completo de medicamentos: tomados, omitidos o pospuestos.
- Escalabilidad para agregar nuevos sensores en el futuro (por ejemplo, glucosa o presión arterial).
- Cálculo de promedios y tendencias, como frecuencia cardíaca semanal o mensual.

MongoDB facilita la evolución del proyecto sin afectar la estructura general del sistema.

Estructura Web



Bitácoras del desarrollo de software





UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

I. Aviso de privacidad

El equipo de desarrollo del proyecto denominado “Pulso” (Gestión de Cuidado para Adultos Mayores), perteneciente a la carrera de Ingeniería en Desarrollo y Gestión de Software de la Universidad Tecnológica de la Zona Metropolitana de Guadalajara (UTZMG), con domicilio en Carretera Santa Cruz–San Isidro Km. 4.5, 45640 Santa Cruz de las Flores, Jalisco, hace de su conocimiento que es el responsable del tratamiento de sus datos personales.

La información recabada, que incluye datos de identificación, datos de contacto, ubicación en tiempo real y datos personales sensibles (como constantes vitales, historial médico y registros biométricos capturados por dispositivos IoT), será utilizada exclusivamente para las siguientes finalidades:

- Monitoreo de salud del adulto mayor.
- Detección de situaciones de riesgo.
- Envío de alertas de emergencia.
- Generación de reportes para el seguimiento del bienestar del adulto mayor.

Se le informa que sus datos personales y datos personales sensibles podrán ser transferidos y compartidos con familiares, tutores legales y profesionales de la salud, previamente autorizados por usted dentro de la plataforma, con el único objetivo de brindar asistencia oportuna y seguimiento médico.

El equipo del proyecto “Pulso” se compromete a implementar las medidas de seguridad técnicas y administrativas necesarias para proteger su información contra daño, pérdida, alteración, destrucción o acceso no autorizado.

Asimismo, usted podrá ejercer en cualquier momento sus Derechos ARCO (Acceso, Rectificación, Cancelación u Oposición) respecto al tratamiento de sus datos personales, así como revocar el consentimiento otorgado para su uso.

Cualquier modificación al presente aviso de privacidad será notificada a través de la plataforma web del sistema “Pulso”.



II. Deslinde de Responsabilidad

Sistema de Monitoreo y Asistencia para Adultos Mayores

Lugar y fecha: _____, a ____ de _____ de 202

Partes Interesada

Desarrolladores

Institución:

Universidad Tecnológica de la Zona Metropolitana de Guadalajara

Integrantes del proyecto:

- Carlos Ivan Machuca Ochoa
- Alejandro Mixteco Tlecuile
- José Daniel Vázquez Barragán

Usuario

Nombre: _____

Edad: _____

Fecha de nacimiento: _____

Contacto de Emergencia

Nombre: _____

Parentesco: _____

Teléfono: _____

Descripción del Sistema

El sistema consiste en una plataforma de monitoreo que integra diferentes dispositivos y aplicaciones tecnológicas para apoyar en el cuidado de adultos mayores. Este incluye:



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

- Aplicación web
- Aplicación móvil
- Smartwatch
- Bocina inteligente (Alexa)
- Pantalla de monitoreo

Estas herramientas permiten el seguimiento de signos vitales, recordatorios de medicamentos y detección de caídas, con el objetivo de apoyar en la supervisión del bienestar del usuario.

Reconocimiento y Aceptación

Ambas partes reconocen que:

1. El sistema forma parte de un proyecto académico en fase de prueba.
2. No sustituye la atención médica profesional ni se considera un dispositivo médico certificado.
3. Los datos generados por el sistema tienen carácter informativo y no diagnóstico.

Deslinde de Responsabilidades

Los desarrolladores no se responsabilizan por:

- Fallas técnicas, de conectividad o de dispositivos.
- Lecturas inexactas de signos vitales.
- Falsas alarmas en la detección de caídas.
- Emergencias médicas no detectadas o atendidas.



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

- Consecuencias derivadas del uso o mal funcionamiento del sistema.
- Pérdida o filtración de datos ocasionada por causas externas.

El usuario o cuidador se compromete a:

- Utilizar el sistema como herramienta complementaria, no como sustituto de atención médica.
- Mantener seguimiento médico profesional regular.
- Verificar periódicamente el correcto funcionamiento de los dispositivos.
- No depender exclusivamente del sistema para situaciones de emergencia.
- Reportar cualquier anomalía o falla a los desarrolladores.

Consentimiento de Datos

El usuario autoriza:

- La recopilación y almacenamiento de datos de salud.
- El acceso del cuidador designado a dichos datos.
- La integración con APIs de terceros (Google Fit, Apple Health, Alexa).
- El uso anónimo de los datos con fines académicos y de investigación.

Firmas de Conformidad



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

Desarrolladores

Firma: _____

Fecha: _____

Usuario

Firma: _____

Fecha: _____

Cuidador / Contacto de Emergencia

Firma: _____

Fecha: _____

III. Lineamientos de Seguridad de la Información en el Desarrollo de Software

El proyecto Pulso, enfocado en el monitoreo en tiempo real de constantes vitales de adultos mayores mediante dispositivos inteligentes y una plataforma web, implica el manejo de información sensible, la interoperabilidad entre sistemas tecnológicos y la responsabilidad ética en el uso de datos de salud.

Por ello, resulta indispensable fundamentar su desarrollo en normas y estándares reconocidos, así como en un marco legal vigente que garantice seguridad, calidad y cumplimiento normativo.

Seguridad de la Información – ISO/IEC 27001

La norma ISO/IEC 27001 establece los lineamientos para implementar un Sistema de Gestión de Seguridad de la Información (SGSI). Su aplicación resulta esencial en el



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

desarrollo del proyecto Pulso debido a que el sistema recopila y almacena datos personales y médicos de los usuarios.

La implementación de esta norma permite definir controles de acceso, mecanismos de autenticación y políticas de manejo de información, los cuales protegen los datos contra accesos no autorizados, pérdidas o alteraciones. Cumplir con esta norma incrementa la confianza de los usuarios y reduce riesgos técnicos y legales asociados a posibles brechas de seguridad.

Calidad del Software – ISO/IEC 25010

La norma ISO/IEC 25010 es relevante para garantizar que el software desarrollado cumpla con criterios adecuados de calidad. Esta norma evalúa características como:

- Funcionalidad
- Usabilidad
- Fiabilidad
- Eficiencia
- Mantenibilidad

En el caso del proyecto Pulso, la usabilidad es un aspecto especialmente importante, ya que el sistema debe ser accesible y fácil de utilizar para adultos mayores, además de ofrecer información clara y confiable para familiares y profesionales de la salud. La aplicación de este estándar contribuye a ofrecer un producto estable, seguro y con una experiencia de usuario adecuada.

Protección de Datos Personales

El proyecto Pulso debe cumplir con la Ley Federal de Protección de Datos Personales en Posesión de los Particulares, ya que maneja información sensible relacionada con la salud de los usuarios.

Esta ley establece la obligación de:

- Obtener el consentimiento informado de los usuarios.



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

- Definir avisos de privacidad claros.
- Garantizar el uso responsable de los datos personales.

Su cumplimiento asegura el respeto a los derechos de los usuarios, tales como Acceso, Rectificación, Cancelación y Oposición (Derechos ARCO), además de prevenir posibles sanciones legales.

Propiedad Industrial

La Ley Federal de Protección a la Propiedad Industrial resulta relevante para proteger los elementos distintivos del proyecto Pulso, tales como el nombre, el logotipo y la identidad corporativa.

La aplicación de esta ley evita el uso indebido de la marca por terceros y permite que el proyecto consolide una identidad propia dentro del sector tecnológico y de la salud. Asimismo, fortalece el valor comercial del proyecto y establece bases para su posible escalabilidad y comercialización futura.

Derechos de Autor

La Ley Federal del Derecho de Autor protege el software, la documentación técnica, el diseño de la plataforma y los contenidos desarrollados en Pulso como obras intelectuales originales.

El cumplimiento de esta legislación garantiza el reconocimiento legal de la autoría del proyecto y evita la reproducción, modificación o distribución no autorizada del sistema. Esto es especialmente importante en proyectos tecnológicos, donde el código y el diseño representan activos intelectuales de gran valor.

Deslinde de Responsabilidad

La incorporación de un deslinde de responsabilidad es necesaria para establecer que Pulso funciona como una herramienta de apoyo para el monitoreo y la prevención, pero no sustituye el diagnóstico ni la atención médica profesional.

Este deslinde permite delimitar el alcance del sistema, reducir riesgos legales y asegurar que los usuarios comprendan el uso correcto de la plataforma. Su inclusión contribuye a promover un uso ético y responsable de la tecnología.



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

Importancia del Cumplimiento de Normas y Estándares

Cumplir con normas y estándares en el desarrollo del proyecto Pulso es fundamental para garantizar que el sistema sea seguro, confiable y legalmente válido. Al tratarse de una plataforma que monitorea constantes vitales de adultos mayores, la seguridad de la información se convierte en un aspecto prioritario, ya que se manejan datos personales y de salud que deben protegerse contra accesos no autorizados.

La aplicación de estándares de seguridad permite asegurar la confidencialidad, integridad y disponibilidad de la información, generando confianza en los usuarios y reduciendo riesgos técnicos y legales.

Asimismo, el cumplimiento de normas relacionadas con la calidad del software garantiza que el sistema sea estable, fácil de usar y eficiente, lo cual es especialmente importante para adultos mayores y sus familiares.

En cuanto al derecho de autor y la propiedad intelectual, respetar la legislación vigente permite proteger el software, la documentación y la identidad del proyecto, evitando el uso indebido por terceros y reconociendo la autoría del desarrollo.

La interoperabilidad tecnológica también se ve fortalecida al seguir estándares reconocidos, ya que facilita la integración entre distintos dispositivos inteligentes y plataformas digitales.

Finalmente, la conformidad con las regulaciones legales, como las leyes de protección de datos personales, asegura un uso ético y responsable de la información.

En conjunto, el cumplimiento de normas y estándares no solo mejora la calidad del proyecto Pulso, sino que también garantiza su viabilidad, aceptación y sostenibilidad a largo plazo.

IV. BlockChain

Aspecto	Sin Blockchain	Con Blockchain
Confianza en datos	Base de datos puede modificarse	Registros inmutables, criptográficamente probados
Cumplimiento legal	Difícil probar consentimientos	Cada consentimiento registrado permanentemente
Disputas legales	"Dijo vs dijo"	Prueba irrefutable de eventos y timestamps
Privacidad	Permisos en código (pueden tener bugs)	Smart contracts automáticos e inmutables
Interoperabilidad	Datos aislados por sistema	Estándar compartido entre dispositivos
Auditorías	Logs pueden borrarse	Historial completo permanente

SEGURIDAD DEL SISTEMA – ENVÍO Y PROTECCIÓN DE DATOS

1. TIPOS DE CIFRADO PARA EL ENVÍO DE DATOS

TLS (Transport Layer Security)

Se utiliza para proteger la información durante su transmisión.

Aplicaciones:

- Comunicación entre smartwatch y servidor
- Comunicación entre aplicaciones (web/móvil) y servidor
- Todas las APIs REST

AES-256

Se utiliza para cifrar datos almacenados.

Aplicaciones:

- Datos almacenados en MongoDB (historial médico, eventos de caídas)
- Archivos de respaldo (backups)
- Datos sensibles en caché (Redis)

bcrypt

Se utiliza para proteger credenciales de acceso.

Aplicaciones:

- Contraseñas de usuarios (cuidadores y adultos mayores)
- PINs de acceso rápido

2. PROTOCOLOS DE SEGURIDAD

HTTPS (HTTP Secure)

Garantiza que la comunicación entre cliente y servidor sea segura.

Aplicaciones:

- Toda la aplicación web (dashboard)
- Todas las APIs REST

OAuth 2.0 + JWT (JSON Web Tokens)

Se utiliza para la autenticación y gestión de sesiones.

Aplicaciones:

- Sistema de login de cuidadores
- Autenticación de la app móvil
- Autenticación del smartwatch
- Manejo de tokens de sesión

WebSocket Seguro (WSS)

Permite comunicación en tiempo real de forma segura.

Aplicaciones:

- Actualización del dashboard en tiempo real
- Notificaciones de emergencia instantáneas
- Transmisión de frecuencia cardíaca cada 5 segundos



CORS (Cross-Origin Resource Sharing)

Controla qué dominios pueden acceder a la API.

Aplicaciones:

- API REST configurada para aceptar únicamente dominios autorizados

3. FIRMAS Y CERTIFICADOS DIGITALES

Certificado SSL/TLS (Let's Encrypt)

¿Qué es?

Es un documento digital que certifica que el servidor es legítimo y no un impostor.

¿Dónde se usa?

- Servidor de APIs
- Dashboard web
- Backend de la aplicación móvil

Firma Digital de Eventos Críticos

¿Qué se firma?

- Eventos de caídas
- Activaciones de SOS
- Cambios en medicamentos
- Accesos a historial médico

Justificación:

Cada evento crítico se firma criptográficamente, similar a firmar un documento legal. Si alguien intenta modificar un evento posteriormente (por



UNIVERSIDAD TECNOLÓGICA DE LA ZONA METROPOLITANA DE GUADALAJARA.

ejemplo, cambiar una hora de registro), la firma deja de coincidir, lo que permite detectar la alteración.

Esto proporciona evidencia forense confiable, útil incluso en contextos legales para demostrar que la información no ha sido manipulada.

Certificados de Dispositivos (Smartwatch)

¿Qué es?

Cada smartwatch cuenta con un certificado digital único.

Justificación:

Esto evita que dispositivos no autorizados envíen datos al sistema. Solo los dispositivos registrados y con certificados válidos pueden comunicarse con el servidor.

Es comparable a una credencial: sin ella, el acceso es denegado.

Flujo de Autenticación del Smartwatch

1. El smartwatch se conecta al servidor
2. Presenta su certificado: "Soy el smartwatch #12345"
3. El servidor verifica el certificado con la Autoridad Certificadora
4. Si es válido, se permite la conexión
5. Si es inválido, se rechaza y se registra como intento sospechoso



PLAN DE PRUEBAS DE SEGURIDAD

Sistema de Monitoreo Integral de Adultos Mayores

1. Objetivo del Plan de Pruebas de Seguridad

El presente plan tiene como propósito definir y documentar los casos de prueba de seguridad que serán ejecutados sobre el Sistema de Monitoreo Integral de Adultos Mayores, el cual está compuesto por cuatro componentes principales: un smartwatch con Wear OS, un skill de Amazon Alexa, una aplicación web (Vue.js + Node.js + MongoDB) y una aplicación móvil (React Native).

Las pruebas de seguridad buscan verificar que el sistema proteja adecuadamente la información sensible de salud de los usuarios, garantice la integridad de los datos transmitidos entre dispositivos, controle correctamente el acceso a cada módulo y resista amenazas comunes como inyecciones, accesos no autorizados y ataques de denegación de servicio.

Este documento establece los casos de prueba planificados. Los resultados obtenidos y las correcciones derivadas serán completados una vez ejecutadas las pruebas en el entorno correspondiente.

2. Entorno de Pruebas

Elemento	Descripción
Sistema Operativo	Windows 10 Pro / Ubuntu 22.04 (servidor staging)
Navegadores	Google Chrome (ultima version), Mozilla Firefox
Frontend Web	Vue.js 3 con Vite
Backend	Node.js v20 + Express.js - staging en localhost:3000
Base de Datos	MongoDB 7.x
App Móvil	React Native - builds de desarrollo en Android 13 / iOS 17
Smartwatch	Wear OS 4 - dispositivo fisico de prueba
Alexa Skill	Amazon Developer Console - Skill en modo de prueba
Protocolo de Comunicación	HTTPS / TLS 1.2+ para todas las conexiones externas

Herramientas de Seguridad	OWASP ZAP 2.14, Postman, BurpSuite Community, MongoDB Compass
Control de Versiones	GitHub - rama develop para pruebas
Lenguaje	JavaScript ES2022, Kotlin (Wear OS)

5. Casos de Prueba de Seguridad

Cada caso se identifica con el formato CPS-XX, donde CPS corresponde a Caso de Prueba de Seguridad y el sufijo indica el componente: AW (Aplicación Web), AM (Aplicación Móvil), SM (Smartwatch), AL (Alexa) e INT (Integración).

Los campos Resultados Obtenidos y Correcciones serán completados durante y después de la ejecución de las pruebas.

5.1. Autenticación y Gestión de Sesiones (Aplicacion Web y Movil)

Caso de Prueba	Título de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
CPS-A W-01	Inicio de sesión con credenciales válidas	El sistema permite el acceso y genera un token JWT con tiempo de expiración correcto. La sesión queda registrada en el servidor.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-02	Inicio de sesión con credenciales inválidas	El sistema rechaza el acceso, muestra un mensaje de error genérico (sin revelar si el usuario existe) y	<i>Pendiente</i>	<i>Pendiente</i>

		registra el intento fallido.		
CPS-A W-03	Bloqueo por intentos fallidos (fuerza bruta)	Tras 5 intentos de login fallidos consecutivos la cuenta queda bloqueada temporalmente y se notifica al administrador.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-04	Expiración de sesión inactiva	La sesión expira automáticamente tras el periodo de inactividad configurado (15 min). El usuario es redirigido al login sin pérdida de datos.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A W-05	Cierre de sesion e invalidacion de token	Al cerrar sesion el token JWT queda invalidado en el servidor. Intentos de reutilizar el token devuelven 401 Unauthorized.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-06	Acceso con token expirado	El sistema rechaza peticiones con tokens expirados con codigo HTTP 401 y mensaje adecuado. No se expone informacion del payload.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A W-07	Restablecimien to de contrasena seguro	El enlace de restablecimiento expira en 30 minutos, es de un solo uso y se envia unicamente al correo registrado. No expone datos del usuario.	<i>Pendiente</i>	<i>Pendiente</i>
---------------	---	---	------------------	------------------

5.2. Control de Acceso por Roles

Caso de Prueb a	Titulo de Prueba	Resultados Esperados	Resultados Obtenidos	Correccione s
--------------------------	---------------------	-------------------------	-------------------------	------------------

CPS-A W-08	Cuidador accede solo a sus propios pacientes	Un cuidador autenticado no puede visualizar ni modificar los datos de adultos mayores asignados a otro cuidador. El sistema devuelve 403 Forbidden.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-09	Acceso directo a ruta protegida sin autenticacion	Un usuario no autenticado que intenta acceder a /dashboard o /pacientes es redirigido al login. No se expone ningun dato.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A W-10	Escalada de privilegios horizontal	Un cuidador no puede modificar la configuracion de alertas de otro cuidador manipulando el ID en la URL o en el body de la peticion.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-11	Escalada de privilegios vertical	Un usuario con rol cuidador no puede acceder a funciones de administracion (gestion de usuarios, configuracion global). El endpoint devuelve 403.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A M-01	Acceso a endpoints de API desde app movil sin token	Todas las peticiones a la API REST desde la app movil sin token de autenticacion son rechazadas con HTTP 401. No se retorna informacion medica.	<i>Pendiente</i>	<i>Pendiente</i>
---------------	---	---	------------------	------------------

5.3. Validacion de Entradas y Proteccion contra Inyecciones

Caso de Prueba	Titulo de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
----------------	------------------	----------------------	----------------------	--------------

CPS-A W-12	Inyeccion NoSQL en campo de login	Al ingresar operadores MongoDB ({"\$gt":""}) en los campos de usuario/contrasena, el sistema los trata como texto plano y rechaza la autenticacion.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-13	Cross-Site Scripting (XSS) en formularios	Ingresar scripts maliciosos en campos de nombre o notas medicas no ejecuta codigo. Los datos se almacenan escapados correctamente.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A W-14	Inyeccion en parametros de busqueda y filtros	Parametros de busqueda con caracteres especiales o operadores son sanitizados antes de la consulta. No se exponen datos de otros usuarios.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-15	Manipulacion de parametros en URL (IDOR)	Cambiar el ID de paciente en la URL no permite acceder a datos de otro paciente si el cuidador no tiene permiso asignado.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A M-02	Inyeccion en campos de configuracion de la app movil	Campos como nombre del medicamento o umbral de alerta con caracteres especiales son validados y no causan comportamiento inesperado en el backend.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A M-03	Manipulacion del body en peticion de emergencia	Un body manipulado en POST /emergencia (cambio de userId) es rechazado; el sistema valida que el userId corresponda al token autenticado.	<i>Pendiente</i>	<i>Pendiente</i>

5.4. Cifrado de Comunicaciones y Datos en Reposo

Caso de Prueba	Título de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
CPS-I NT-01	Toda la comunicacion usa HTTPS/TLS	Interceptando trafico con Wireshark, ninguna peticion entre la app y el servidor viaja en texto plano. Se confirma uso de TLS 1.2 o superior.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-I NT-02	Comunicación smartwatch-backend cifrada	Los datos de signos vitales transmitidos desde el smartwatch al backend viajan cifrados. No es posible leerlos en texto plano desde la red local.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-I NT-03	Contraseñas almacenadas con hash seguro	Verificando directamente en MongoDB, las contraseñas de usuarios se almacenan como hash bcrypt. No existe ningún campo con contraseña en texto plano.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-I NT-04	Datos medicos en reposo no expuestos en logs	Los logs del servidor no registran datos medicos sensibles (frecuencia cardiaca, signos vitales, medicamentos). Solo se registran metadatos.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-I NT-05	Tokens JWT correctament e configurados	Los tokens JWT usan firma HS256 o RS256, incluyen expiracion (exp) e identificador de emisor (iss). No exponen datos sensibles en su payload.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A M-04	Datos locales en la app movil cifrados	Los datos en cache local de la app (ultimos signos vitales, alertas) estan cifrados con el almacenamiento seguro del dispositivo (Keychain/Keystore) .	<i>Pendiente</i>	<i>Pendiente</i>
---------------	--	---	------------------	------------------

5.5. Seguridad del Smartwatch (Wear OS)

Caso de Prueba	Título de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
CPS-S M-01	Emparejamiento seguro con smartphone	El proceso de vinculacion smartwatch-smart phone requiere confirmacion en ambos dispositivos. No es posible vincular un smartwatch de forma silenciosa.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-S M-02	Datos locales del smartwatch protegidos	Las lecturas de signos vitales almacenadas localmente en el smartwatch no son accesibles desde otras apps instaladas en el dispositivo.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-S M-03	Alerta de emergencia SOS no suplantable	El boton SOS genera una alerta firmada con el ID del dispositivo. No es posible generar una alerta falsa en nombre del smartwatch desde otra fuente.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-S M-04	Resiliencia ante desconexión del smartphone	Si el smartwatch pierde conexión con el teléfono, sigue registrando datos localmente y muestra indicador de desconexión. Al reconectar sincroniza sin pérdida.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-S M-05	Actualizaciones OTA verificadas	Las actualizaciones del firmware solo se aplican si tienen firma digital válida del servidor oficial. Se rechaza cualquier paquete no firmado.	<i>Pendiente</i>	<i>Pendiente</i>

5.6. Seguridad del Skill de Alexa

Caso de Prueba	Título de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
CPS-AL-01	Autenticación de cuenta vinculada a Alexa	El Skill requiere Account Linking activo. Si el usuario no ha vinculado su cuenta, Alexa solicita autorización antes de ejecutar cualquier comando sensible.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-AL-02	Comando de emergencia no activado por voz no autorizada	El comando de ayuda solo dispara la secuencia de emergencia si el perfil de voz corresponde al usuario registrado o al hogar configurado.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-AL-03	Proteccion de datos medicos verbales	Al consultar signos vitales por voz, Alexa no repite informacion medica completa en voz alta si hay modo de privacidad activo. Solo confirma estado general.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-AL-04	Validacion de origen de peticiones al backend desde Alexa	El backend verifica que las peticiones del Skill de Alexa incluyan la firma de Amazon. Peticiones sin firma son rechazadas con 403 Forbidden.	<i>Pendiente</i>	<i>Pendiente</i>



UNIVERSIDAD TECNOLÓGICA DE LA ZONA
METROPOLITANA DE GUADALAJARA.

CPS-AL-05	Manejo seguro de tokens de Alexa Account Linking	Los tokens de acceso de Alexa se almacenan cifrados. El sistema refresca los tokens correctamente antes de su expiracion sin exponer credenciales en logs.	<i>Pendiente</i>	<i>Pendiente</i>
-----------	---	--	------------------	------------------

5.7. Seguridad de la API REST (Backend Node.js)

Caso de Prueba	Título de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
CPS-A W-16	Rate limiting en endpoints criticos	El endpoint POST /login y POST /emergencia tienen limite de velocidad configurado. Mas de 20 peticiones por minuto desde una misma IP retorna 429.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A W-17	Headers de seguridad HTTP correctamente configurados	Las respuestas del servidor incluyen: Content-Security-Policy, X-Frame-Options DENY, X-Content-Type-Options nosniff y Strict-Transport-Security. Verificado con OWASP ZAP.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-18	CORS configurado correctamente	Solo los orígenes autorizados (dominio de la app web y móvil) pueden hacer peticiones cross-origin. Peticiones desde orígenes no autorizados son rechazadas.	<i>Pendiente</i>	<i>Pendiente</i>

CPS-A W-19	No exposicion de informacion en errores del servidor	Los errores 500 no exponen stack traces, version de Node.js, estructura de la base de datos ni rutas internas. Se retorna un mensaje generico al cliente.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A W-20	Validacion de esquema en body de peticiones	Peticiones con campos adicionales no esperados o tipos de dato incorrectos son rechazadas con 400 Bad Request. No se almacenan campos no declarados.	<i>Pendiente</i>	<i>Pendiente</i>

UNIVERSIDAD TECNOLÓGICA DE LA ZONA
METROPOLITANA DE GUADALAJARA.

CPS-A W-21	Proteccion ante subida de archivos maliciosos	Si el sistema permite subida de archivos, solo se aceptan formatos de imagen permitidos. Archivos ejecutables o con extensiones no autorizadas son rechazados.	<i>Pendiente</i>	<i>Pendiente</i>
---------------	--	--	------------------	------------------

5.8. Integridad de Alertas y Notificaciones de Emergencia

Caso de Prueba	Título de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
CPS-I NT-06	Alerta de emergencia no puede ser suprimida maliciosamente	Una vez generada una alerta de caída o SOS no puede ser cancelada desde una sesión no autorizada. Solo el cuidador autenticado puede marcarla como atendida.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-I NT-07	Notificaciones push firmadas y no suplantables	Las notificaciones push enviadas a la app móvil incluyen un identificador verificable. La app descarta notificaciones	<i>Pendiente</i>	<i>Pendiente</i>

		que no provengan del servidor autorizado.		
CPS-I NT-08	Registro de auditoria de alertas	Cada alerta de emergencia queda registrada en el log de auditoria con: timestamp, origen (smartwatch/SOS/Alexa), usuario afectado y acciones tomadas.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-A M-05	Notificaciones de emergencia en dispositivo bloqueado	Las alertas de emergencia se muestran en la pantalla de bloqueo del smartphone del cuidador con sonido de alta prioridad, incluso con el telefono en silencio.	<i>Pendiente</i>	<i>Pendiente</i>

5.9. Seguridad de la Base de Datos (MongoDB)

Caso de Prueba	Título de Prueba	Resultados Esperados	Resultados Obtenidos	Correcciones
CPS-I NT-09	Acceso a MongoDB solo desde el backend	El puerto de MongoDB (27017) solo acepta conexiones desde la IP del servidor Node.js. Intentos de conexión directa desde IPs externas son rechazados.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-I NT-10	Autenticación requerida en MongoDB	La instancia de MongoDB tiene autenticación habilitada. No es posible conectarse sin usuario y contraseña válidos	<i>Pendiente</i>	<i>Pendiente</i>

		con los permisos adecuados.		
CPS-I NT-11	Principio de minimo privilegio en usuario de BD	El usuario de MongoDB usado por la aplicacion solo tiene permisos de lectura/escritura sobre las colecciones necesarias. No tiene permisos de administracion.	<i>Pendiente</i>	<i>Pendiente</i>
CPS-I NT-12	Backups de datos medicos cifrados	Los respaldos automaticos de la base de datos se almacenan cifrados. No es posible leer datos medicos de un backup sin la clave	<i>Pendiente</i>	<i>Pendiente</i>



UNIVERSIDAD TECNOLÓGICA DE LA ZONA
METROPOLITANA DE GUADALAJARA.

		de descifrado correspondiente.		
--	--	-----------------------------------	--	--